



Bases Protée

Protée
IT, app design

Toulouse, le 13 mars 2018

Biblika

UTILISATEURS ET MOTS DE PASSE

Version	Date	Rédacteur	Commentaires
01	13/03/2018	OG	Première version

Protée sarl
au capital de 7 622 €
RC B 404 445 629

<http://www.protee.org>
info@protee.org
Tél : 0970 46 56 46
Mob : 0660 49 33 23

• 148 rue du Fbg St Denis
75010 PARIS
• 32 Bis rue des Lois
31000 TOULOUSE



1. Introduction

La sécurité devient un sujet de plus en plus important car les applications d'entreprise deviennent accessibles par le web et sont, par conséquent, plus vulnérables aux menaces. Comme Protée fait attention aux questions de sécurité, nous vous apportons quelques améliorations de sécurité, et l'une d'entre elles se rapporte à la protection par mot de passe des utilisateurs par hachage de mot de passe.

Pourquoi les mots de passe doivent être illisibles ?

Prenons un exemple concret - vous avez une application métier, avec des utilisateurs qui peuvent se connecter en entrant son nom et mot de passe dans une boîte de dialogue. Une fois connectés, les utilisateurs bénéficient des « droits supplémentaires » tels que la lecture et l'écriture dans d'autres tables ou des champs (par exemple, le département des ressources humaines peut accéder à la table des salaires des employés, mais pas les employés eux-mêmes).

Le serveur doit alors stocker « quelque chose » qui sera utilisé pour vérifier les mots de passe de l'utilisateur. Le « quelque chose » le plus élémentaire se compose des mots de passe eux-mêmes !

Tout mot de passe non sécurisé enregistré dans votre base de données peut être volé et utilisé pour compromettre votre application et vos données. Le pire, c'est qu'un mot de passe trouvé dans un outil peut être utilisé pour accéder à d'autres ressources, car ce sont souvent les mêmes !

Si vous hachez votre mots de passe avant de l'enregistrer dans votre base de données, le mot de passe d'origine ne peut pas être trouvé ou déchiffré. Mais, vous pouvez toujours comparer le hachage du mot de passe d'origine pour vérifier la validité.

Hacher ou crypter ?

La première chose à noter est qu'on parle de mots de passe cryptés, mais on devrait vraiment parler de mots de passe hachés.

Le cryptage utilise un algorithme pour encoder des données qui peuvent être décryptés par une clé pour obtenir les données originales de retour. En hash, une fois que les données sont codées, il n'y a aucun moyen de récupérer les données d'origine. Ainsi, les mots de passe doivent être hachés et non chiffrés.

Une conséquence de hachage de mot de passe est que, puisque vous ne stockez pas les mots de passe eux-mêmes - mais seulement une donnée qui est suffisante pour vérifier un mot de passe sans être en mesure de le récupérer, vous ne pouvez pas renvoyer leurs mots de passe aux utilisateurs qui auraient oublié le leur. Au lieu de cela, vous devez sélectionner un nouveau mot de passe aléatoire pour eux, ou les laisser choisir un nouveau mot de passe.

QUEL ALGORITHME POUR LE HACHAGE?

Les algorithmes comme MD5 ou SHA sont très rapides, donc ils sont vulnérables aux attaques de force brute. En conséquence, ils ne doivent pas être utilisés pour hachage des mots de passe. Le « bcrypt » est un algorithme lent par sa conception, il vise à être lent, et il est donc parfaitement adapté pour le hachage de mot de passe.



Les bases Protée

Les bases de données de Protée intègre une gestion des mots de passe, qui a été revisité pour mieux garantir la sécurité des connexions. Avant :

- Mots de passe stockés en clair dans la base de données. Problème de confidentialité.
- Facilité pour renvoyer un mot de passe, sans contraintes aucunes.

C'est pour cela que le module a été revisité pour vous proposer la version v2, qui corrige les faiblesses d'origine.

Ainsi maintenant :

- Mots de passe stockés en « haché », sur plusieurs algorithmes, dont le « en clair »...
- Plus de possibilité de lire ces mots de passe
- Revisite totale de la création de ces mots de passe :
 - Fenêtre dédiée pour vérifier, ou changer (avec double test)
 - Proposition d'envoi par email des identifiants de connexion (après, c'est trop tard).
- Création automatisée des fiches utilisateurs depuis les tables associées.
 - **CONCERTO** : Enseignants et Familles
 - **Fyo** : Associations et Personnes
 - ...
- Utilitaire de régénération des mots de passe avec envoi des identifiants de connexion.

Le système est maintenant fiable, abouti et surtout conserve l'ancien mode sans risque et sans manœuvre complexe, et pour une transition en douceur.



II) Conversion des bases existantes

Vous n'avez rien à faire, il n'y a pas de conversion. Par contre, vous devez volontairement lancer un utilitaire qui va convertir tous les mots de passe en clair dans un hachage selon un algorithme choisi.

III) Réglages et définitions

Vous accédez au paramétrage par le menu « Paramètres -> Réglages ». Vous définissez ici sous quel algorithme de hachage les nouveaux utilisateurs créés seront stockés.

Les algorithmes existants sont :

- en clair - ancien système à oublier !
- MD5 - hachage rapide donc mauvais
- SHA1 - ne plus utiliser
- digest 4D - système de 4D
- bcrypt - le dernier bébé de la sécurité. Il est lent par construction et ne permet donc pas la « force brute ».

Nous vous recommandons donc « bcrypt » ! Les autres sont là pour assurer la compatibilité avec ce que vous pourriez être amenés à rencontrer (accès externes, comme pour AXEL et la mairie de Suresnes).

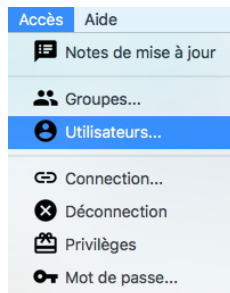


Attention ! Choisir un digest de mot de passe ne signifie pas que les mots de passe soient convertis. En effet, les bases Protée gèrent, par mot de passe, le digest utilisé. Ainsi tous les types peuvent coexister dans une même base, y compris le « en clair ».



IV) Utilisateurs

Vous accédez au utilisateurs...



La liste comporte maintenant, pour chaque enregistrement, le type de hashage en colonne « psw ».

login	nom	sigle	groupe	ass_id	per_id	psw	web
Y.P.T.S. YOGA POUR TOUS SAUSSET	Y.P.T.S. YOGA POUR TOUS SAUSSET	ASS		126	-	4D	☒
Y.T. YOGA TEICHOIS	Y.T. YOGA TEICHOIS	ASS		145	-	4D	☒
Elise	Elise SAVIDAN	ES	Administrateurs	-	7 540	4D	☒
Fm	Fiduciaire Mallet FIDUCIAIRE MALLET	FM	Comptables	-	-	4D	☐
Patrick D.	Patrick DENNERY	PD	Comptables	-	-	MD5	☐
E-Mailing Efy	Efy	E	E-mailing	-	-	MD5	☐
E-Mailing Fney	Fney	F	E-mailing	-	-	MD5	☐
Zitoune	Olivier Grimbart	OG	Ouverture	-	-	bcrypt	☒
Aida	Aida AW	AW	Secrétariat	-	-	SHA1	☐
Audrey	Audrey ANTONY	AA	Secrétariat	-	-	SHA1	☐
Catherine	Catherine LE GALLAIS	CL	Secrétariat	-	-	SHA1	☐

- Une coche vous permet d'indiquer si l'utilisateur peut se connecter par le web ou pas.
- Certaines fiches Utilisateurs sont associées à des tables internes « métier », comme ici ass_id et per_id. Ainsi, un Utilisateur connecté peut se voir attribuer un rôle et un contexte.

V) Gestion du mot de passe

La fiche d'utilisateur comporte maintenant un bouton qui ouvre une fenêtre de gestion du mot de passe.

Pourquoi ? Car :

- il n'est plus possible de retrouver un mot de passe, aussi faut-il pouvoir le tester
- quand vous en créez un nouveau, il doit être certain et on doit pouvoir s'en rappeler. Aussi :
 - vous devez le saisir deux fois pour garantir sa bonne saisie
 - vous pouvez en générer un « costaud » d'un clic
 - vous pouvez l'envoyer aux emails des tables associées éventuelles



Menu déroulant de choix du type de hachage.

Bouton d'ouverture de la fenêtre de gestion du mot de passe.

Ici, vérification d'un mot de passe. Vous tapez le mot de passe à vérifier, et vous obtenez soit la bulle grise, soit verte cochée « ok ».

Ici, vous pouvez entrer un nouveau mot de passe, en le tapant deux fois, puis validant.

A ce moment, et si la fiche Utilisateur est connecté à une ou des tables qui comportent des emails, une alerte vous propose « d'envoyer les identifiants de connexion ».

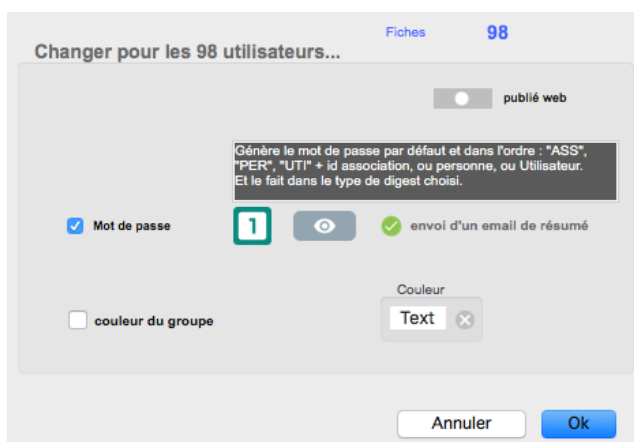
Le bouton vert va vous permettre de générer un mot de passe complexe, comme « Y1e-u5PqBBu » !



VI) Utilisateurs, Changement d'options

Trois options sont disponibles pour la génération des mots de passe.

1. va générer les mots de passe par un résumé de la table liée, suivi de l'ID de l'enregistrement lié, et dans l'ordre indiqué, ici : ASS, puis PER, puis UTI.
2. Génération d'un mot de passe complexe
3. Génération d'un mot de passe haché et à l'identique pour ceux qui sont en clair (donc lisible). Les autres restent inchangés.



Vous choisissez :

- Le mode 1, 2, ou 3
- l'algorithme de hachage
- si vous souhaitez envoyer un email automatiquement à ceux qui en ont un

La fenêtre vous permet aussi de définir

- les enregistrements sélectionnés seront publié web ou pas
- reporter la couleur du groupe
- reporter une couleur choisie dans l'interface

VII) Hacher les mots de passe existants



Tous vos mots de passe actuels sont à priori de type « en clair ». Il est donc important de les hacher, de préférence en « bcrypt ». Pour cela :

1. allez dans les préférences et choisissez le digest « bcrypt ». Sauvez.
2. ouvrir la liste des utilisateurs
3. allez dans le menu « Actions » -> « Chgt Options ».
4. cliquez sur « mot de passe ». Sélectionnez le mode 3. Mettre sur « bcrypt ». Validez.

Tous vos mots de passe « en clair » sont devenus des « bcrypt », bien hachés, illisibles, non récupérables.



VIII)Création des utilisateurs

Des utilitaires de création dédiés « Métier » sont proposés, comme ici avec l'exemple de Fyo et les Associations.

Libellé	Sigle	c	CP	Ville	e	n	Référence	Cotisants	F	U
A. P. E. P. Y.	A.P.E.P.Y.	✓	94100	SAINT MAUR DES FOSSES	✓	✓	7	12	✓	U
ANIMATEURS SÉMINAIRE		✓	75004	PARIS	✓	✓		32	✓	U
ASSOCIATION ACCORD A CORPS	ACAC	✓	83150	Bandol	✓	✓	249	60	✓	U
ASSOCIATION ASANA	A.S.A.N.A	✓	67550	VENDENHEIM	✓	✓	274	12	✓	U
ASSOCIATION AUVERSOISE DE YOGA	A.A.Y.	✓	95430	AUVERS SUR OISE	✓	✓	77	19	✓	U
ASSOCIATION BRIE LOISIRS ET CULTURE	B.L.C	✓	16590	BRIE	✓	✓	321	73	✓	U
ASSOCIATION DES AMIS DE LA VIOLLE	A.A.M	✓	22400	LAMBALLE	✓	✓	334	15	✓	U
ASSOCIATION GENERALE DES ADEPTES DU YOGA	A.G.A.Y.	✓	75116	PARIS	✓	✓	12	108	✓	U
ASSOCIATION LILOISE DE YOGA	ALY	✓	59000	LILLE	✓	✓	258	118	✓	U
ASSOCIATION MARIGNANAISE DE YOGA	A.M.Y	✓	13700	MARIGNANE	✓	✓	259	72	✓	U
ASSOCIATION SOLEILUNE	A.S	✓	54220	MALZEVILLE	✓	✓	318	69	✓	U
ASSOCIATION SPORTIVE NANTOISE YOGA	A.S.N.	✓	77176	NANDY	✓	✓	251	57	✓	U
ATELIER DE YOGA ET DU MIEUX ETRE	A.Y.M.E.	✓	42300	ROANNE	✓	✓	26	10	✓	U
AU FIL DE SOI		✓	16450	LUSSAC	✓	✓	278	61	✓	U
AVENIR DE COURTENAY	A.C.	✓	45220	MONTCORBON	✓	✓	162	10	✓	U

- Vous sélectionnez les enregistrements à prendre en compte
- Vous allez au menu « Actions » -> « Créer les utilisateurs »

Pour les 83 enregistrements...

Groupe

Vous pouvez laisser le groupe vide pour les accès web. Les droits dépendront du rôle de chaque utilisateur.

☒ web

☐ réinitialiser les existants

Dans tous les cas, le groupe et l'option "web" seront mis à jour, même pour les Utilisateurs déjà existants.

☒ envoi de l'email d'identification

A ce stade, vous pouvez :

- choisir un groupe éventuel où rattacher les Utilisateurs qui seront créés
- indiquer si l'option « web » sera cochée ou pas
- pour les enregistrements avec déjà une fiche Utilisateurs de créée, choisir de réinitialiser toutes les infos. Sinon seuls le groupe et l'option web seront mis à jour.
- indiquer si vous souhaitez un envoi par email des identifiants générés, pour ceux qui ont un email



Pour les enregistrements de la table, sans enregistrement Utilisateurs existant :

- les utilisateurs seront créés pour les enregistrements de « Associations »
- L'utilisateur généré sera ici le Sigle + espace + Libellé
- Le mot de passe généré sera « ASS » + l'identifiant de chaque association, comme « ASS827 ».

Pour les enregistrements de la table, avec déjà un enregistrement Utilisateurs existant :

- l'option web sera mis à jour
- le groupe sera mis à jour
- les autres données seront mises à jour, comme en création, si l'option « réinitialiser les existants » est cochée.



Il est recommandé de ne pas mettre de groupe pour les utilisateurs web : ainsi ils n'auront aucun droits s'ils se connectent sur votre base Protée depuis un poste « client lourd ».

9. Conclusion

En espérant que ce nouveau module de gestion de la sécurité trouvera écho et vous satisfasse, n'hésitez pas surtout à basculer avec le mode « bcrypt » rapidement - voir chapitre VII.